

SalesVerse 2.0

Security Assessment Report

Internal pre-implementation assessment: automated checks, configuration and code review

Prepared for	Insurans Islam Family Takaful Sendirian Berhad
Solution	IIFT Agent/Banca Portal & Back-office
Build assessed	Commit 8651425
Checks run	2 October 2026, 14:04 UTC
Assessment type	Internal (iorta TechNXT); not an independent penetration test
Document date	October 2026
Version	1.0
Classification	Commercial-in-Confidence

Commercial-in-Confidence. Prepared by iorta TechNXT for Insurans Islam Family Takaful Sendirian Berhad as part of the proposal for the Agent/Banca Portal and Back-office Solution.

Contents

Contents.....	2
1. Scope and environment.....	3
2. Method.....	4
3. Summary of results.....	5
4. Detailed results.....	6
5. Security controls implemented.....	8
6. Configuration review.....	9
Web-tier headers and limits (nginx).....	9
API response headers (observed).....	9
Cookies, secrets and production guards.....	9
Containers and pipeline.....	9
7. Dependency vulnerabilities.....	10
8. Residual risks and recommendations.....	11
9. Vulnerability severity and remediation timelines.....	11
10. Independent VAPT plan.....	12
Annex – Evidence files.....	13

Nature of this assessment

This is iorta TechNXT's **internal** assessment of the current build: automated application security checks, plus configuration and code review, in a test environment with demonstration data.

It is **not** an independent penetration test. An independent third-party VAPT on IIFT's UAT or production-like environment is scheduled before go-live (DEL-17), followed by remediation and re-test. Section 10 sets out that plan.

1. Scope and environment

Item	Detail
Build assessed	SalesVerse 2.0, commit 8651425
Environment	Test environment at http://localhost:3001 with demonstration data; not production
Automated checks run	2 October 2026, 14:04 UTC
In scope	API (NestJS) and its HTTP pipeline, authentication and sessions, authorisation and data scoping, uploads and document storage, field encryption, audit trail, web-tier configuration (nginx), container images, CI pipeline, dependencies
Out of scope	IIFT/IITH infrastructure and network, IIFT systems behind the integration adapters, denial-of-service, social engineering, physical security; these belong to the independent VAPT and IITH's own controls

Table 1: Scope

2. Method

The assessment follows the OWASP Top 10 (2021) and the OWASP Application Security Verification Standard (ASVS) Level 2 areas for authentication, session management, access control, input validation, cryptography at rest, error handling and logging, data protection, file handling and configuration.

Automated checks are run by tools/security/security-checks.mjs against a freshly built, non-production instance loaded with demonstration data. Each check signs in as the relevant demonstration user, sends a crafted request (wrong credentials, another agency's identifiers, injection payloads, executable uploads, missing CSRF tokens and so on) and records what was sent, what was expected and what came back. Because the script changes data and triggers lockouts and rate limits, it must never run against production.

Code and configuration review covered: the HTTP pipeline (app.setup.ts), the authentication module and guards, the security helpers in common/security, field encryption, the file inspector and document storage, the audit trigger in the database migration, start-up configuration and production guards, the web-tier nginx configuration, both Dockerfiles, the compose deployment and the CI pipeline.

3. Summary of results

29 of 29 automated checks passed. npm audit reports 0 known vulnerabilities. No Critical or High finding is open from this assessment. The residual risks in section 8 are improvements to be made during implementation, mostly in the hosting environment, together with the independent VAPT.

OWASP Top 10 2021	Checks	Passed	Result	Other evidence
A01 Broken Access Control	8	8	Pass	
A02 Cryptographic Failures	2	2	Pass	Code review: AES-256-GCM field and document encryption; Argon2id password hashing
A03 Injection	3	3	Pass	
A04 Insecure Design	2	2	Pass	Design review: maker-checker enforced by the API; server-side business rules
A05 Security Misconfiguration	3	3	Pass	Configuration review: production guards, web-tier headers, non-root containers
A06 Vulnerable and Outdated Components	0	0	No automated check	npm audit (0 findings); container image scan in CI
A07 Identification and Authentication Failures	6	6	Pass	
A08 Software and Data Integrity Failures	3	3	Pass	CI pipeline with locked dependencies (npm ci); signed release images planned
A09 Security Logging and Monitoring Failures	2	2	Pass	Code review: structured logs with correlation id and header redaction; audit table append-only
A10 Server-Side Request Forgery	0	0	No automated check	Code review: outbound calls go only to endpoints set in configuration; no user-supplied URLs are fetched

Table 2: Results by OWASP category

4. Detailed results

ID	OWASP	Check	Expected	Result	Evidence summary
SEC-09	A01	Protected endpoints require a session	401 without a session	Pass	status: 401
SEC-10	A01	Portal users cannot call back-office APIs	403 WRONG_AUDIENCE for portal users on back-office routes	Pass	status: 403; code: WRONG_AUDIENCE
SEC-11	A01	Another agency's policy cannot be read by changing the identifier (IDOR)	404: record outside the user's agency is not disclosed	Pass	status: 404
SEC-12	A01	Another agency's documents cannot be downloaded	403 for another agency's document	Pass	status: 403
SEC-13	A01	Participant profiles are limited to agencies that hold business with them	403 for participants with no business in the user's agency	Pass	status: 403
SEC-14	A01	Users cannot grant themselves permissions they do not hold	403 when granting permissions the user does not hold	Pass	status: 403
SEC-15	A01	State-changing requests require the session's own CSRF token	403 without the session's own CSRF token	Pass	missing: 403; otherSessionsToken: 403
SEC-29	A01	E-signature links cannot be guessed; invalid tokens reveal nothing	Malformed and unknown tokens reveal nothing	Pass	malformed: 404; wellFormedButUnknown: 422
SEC-25	A02	Identification numbers are returned masked; ciphertext and hashes are never returned	Identifiers masked; no ciphertext or blind index returned	Pass	5 identifiers returned masked, e.g. *4658
SEC-26	A02	Password hashes are never returned by the API	No password hash in any user response	Pass	status: 200
SEC-17	A03	SQL/NoSQL/template injection payloads in search are treated as text	Payloads treated as text: no extra records, no errors, no delay	Pass	10 payloads; all HTTP 200; no records leaked (0); slowest 14 ms
SEC-18	A03	Injection in sign-in fields is rejected as invalid credentials	401 invalid credentials	Pass	status: 401
SEC-19	A03	LDAP filter characters in usernames do not alter directory queries	401; LDAP filter characters escaped	Pass	status: 401
SEC-20	A04	Negative, future-dated and excessive payments are refused	Negative, future-dated and excessive amounts refused	Pass	negative: 400; futureDate: 422; aboveOutstanding: 422
SEC-21	A04	Unexpected fields (mass assignment) are rejected	400 listing the unexpected properties	Pass	status: 400; details: property amlStatus should not exist; property createdByAgencyId should not exist
SEC-01	A05	Security headers on API responses	HSTS, nosniff, frame and content-security headers present; X-Powered-By absent	Pass	Present: strict-transport-security, x-content-type-options, x-frame-options, content-security-policy. Absent: x-powered-by
SEC-02	A05	Unknown routes return a generic JSON error without framework details	404 with code and correlation id only; no framework detail	Pass	status: 404; body: statusCode=404, code=NOT_FOUND, message=Cannot GET /api/v1/does-not-exist
SEC-03	A05	Malformed JSON is rejected without a stack trace	400 without stack trace	Pass	status: 400; body: statusCode=400, code=BAD_REQUEST, message=Unexpected end of JSON input
SEC-04	A07	Same response for unknown user and wrong password (no user enumeration)	Identical message for unknown user and wrong password	Pass	unknownUser: Invalid username or password; wrongPassword: Invalid username or password
SEC-05	A07	Session cookie is HttpOnly and SameSite=Strict (Secure is enforced in production configuration)	HttpOnly and SameSite=Strict; Secure enforced by production configuration	Pass	Set-Cookie: iift.sid=<redacted>; Path=/; HttpOnly; SameSite=Strict
SEC-06	A07	Session identifier changes at every sign-in (no session fixation)	New session identifier after sign-in	Pass	changed: True
SEC-07	A07	A session cookie cannot be reused after logout (server-side revocation)	Old cookie rejected (401) after logout	Pass	status: 401
SEC-08	A07	Sign-in attempts are rate limited per client (HTTP 429)	HTTP 429 once the per-client sign-in limit is reached	Pass	12 of 12 attempts after the limit returned 429
SEC-30	A07	System-to-system APIs require an API key	Request without a valid key refused (401), or interface disabled (503) when no key is configured	Pass	status: 503
SEC-22	A08	Uploads are checked by content: executables, HTML and SVG are refused	422 for executable, HTML and SVG content	Pass	exe: 422; html: 422; svg: 422

ID	OWASP	Check	Expected	Result	Evidence summary
SEC-23	A08	Uploads above the size limit are refused	422 FILE_TOO_LARGE	Pass	status: 422; code: FILE_TOO_LARGE
SEC-24	A08	Path elements in file names are removed	Stored name stripped of path elements	Pass	status: 201; storedName: passwd.pdf
SEC-27	A09	Failed sign-ins are recorded in the audit trail with IP address	LOGIN_FAILED events with IP address in the audit trail	Pass	12 failure events; sample LOGIN_FAILED from 127.0.0.1
SEC-28	A09	Every response carries a correlation id for tracing	X-Request-Id on every response	Pass	x-request-id: 88581812-565b-434b-84ea-ed9132bc84c0

Table 3: Automated security checks

Check IDs follow the script's numbering; the gap at SEC-16 is intentional. Cookie values are redacted in the evidence.

5. Security controls implemented

The controls below are in the current build. Default values are read from the platform's settings definitions and can be changed by IIFT administrators under maker-checker.

Control	Implementation	RFP reference
Authentication	Argon2id password hashing (OWASP parameters); identical message for unknown user and wrong password; Active Directory sign-on for back-office users with escaped LDAP filters	AP-01, NFR-09, INT-06
Password policy	At least 12 characters with upper case, lower case, digit and symbol; last 5 passwords blocked; expiry 90 days; username not allowed; all configurable	AP-02
Sessions	Server-side sessions in PostgreSQL; new session id at sign-in; HttpOnly, SameSite=Strict cookie, Secure in production; 15-minute idle and 8-hour absolute timeout; single active session on; revocation at logout and on password change	AP-03
Lockout and rate limits	Account locked for 30 minutes after 5 failed attempts; sign-in limited per client address (HTTP 429); global request limit; web-tier request limit	AP-04, NFR-09
Authorisation	Permission guard on every route; separate portal and back-office audiences; data scoping by agency and hierarchy; users cannot grant permissions they lack	COM-02, NFR-10
CSRF	Synchroniser token issued at sign-in, checked in constant time on every state-changing request	NFR-14
Encryption in transit	HSTS on API and web tier; TLS terminated at the web tier or load balancer	COM-10, NFR-08
Encryption at rest	IC and passport numbers encrypted with AES-256-GCM (random IV, authentication tag, key version prefix) and an HMAC-SHA256 blind index; documents encrypted with AES-256-GCM and stored with mode 0600	COM-01, COM-10, NFR-08
Input validation	DTO whitelist with forbidNonWhitelisted; 2 MB JSON limit; parameterised database access	NFR-14, NFR-30
File uploads	Type detected from content (PDF, PNG, JPEG only); extension forced to match; size limit; path elements removed; SHA-256 recorded; ClamAV scan when configured	AP-46, COM-06
Audit trail	Append-only audit_log: a database trigger rejects UPDATE and DELETE; failed and successful sign-ins, lockouts and changes recorded with user, time and IP; sensitive fields redacted	NFR-11, COM-03
Error handling	One global filter returns status, code, message and correlation id; details logged on the server only	NFR-15
System-to-system APIs	Inbound API key compared by SHA-256 hash; interface disabled until a key is configured; web-tier allow-list for IITH addresses	INT-10
Vulnerability management	npm audit and container scan in CI; remediation timelines in section 9	NFR-12, NFR-13

Table 4: Controls mapped to RFP requirements

6. Configuration review

Web-tier headers and limits (nginx)

Directive	Value
X-Content-Type-Options	nosniff
X-Frame-Options	DENY
Referrer-Policy	strict-origin-when-cross-origin
Permissions-Policy	camera=(), microphone=(), geolocation=()
Strict-Transport-Security	max-age=31536000; includeSubDomains
Content-Security-Policy	default-src 'self'; img-src 'self' data: blob:; style-src 'self' 'unsafe-inline'; script-src 'self'; connect-src 'self'; font-src 'self' data:; frame-ancestors 'none'; base-uri 'self'; form-action 'self'
server_tokens	off (nginx version hidden)
limit_req (API)	20r/s per client address with burst
client_max_body_size	26m

Table 5: apps/web/nginx.conf

API response headers (observed)

Header	Value
strict-transport-security	max-age=31536000; includeSubDomains
x-content-type-options	nosniff
x-frame-options	SAMEORIGIN
content-security-policy	default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
x-powered-by	Absent

Table 6: Headers recorded by SEC-01

The web tier sends X-Frame-Options DENY and frame-ancestors 'none'; the API's own headers use SAMEORIGIN. Browsers receive the web-tier values for the application. We will align the API value to DENY during implementation.

Cookies, secrets and production guards

The session cookie is HttpOnly and SameSite=Strict in every environment, and Secure whenever SESSION_COOKIE_SECURE is true, which is the production default. Secrets and keys come from environment variables (deploy/.env, never committed): the session secret must be at least 32 characters and each encryption key must be a base64 32-byte key, or the API refuses to start. In production the API also refuses to start when any of these conditions fails:

- SESSION_COOKIE_SECURE must be true in production
- API_DOCS_ENABLED must be false in production
- CORE_API_BASE_URL is required in live mode
- FINANCE_API_BASE_URL is required in live mode
- SMTP_HOST is required in live mode
- INBOUND_API_KEY_SHA256 is required in live mode

Containers and pipeline

Item	Finding
apps/api/Dockerfile	Runs as 'salesverse' (non-root); base image node:22-bookworm-slim
apps/web/Dockerfile	Base image nginxinc/nginx-unprivileged:1.29-alpine runs nginx as a non-root user
Dependency audit	npm audit --audit-level=moderate
Container image scan	Trivy; fails on CRITICAL,HIGH (fixable)

Item	Finding
Runtime dependencies	API image installs production dependencies only (npm ci --omit=dev)
Health checks	Both images define container health checks

Table 7: Container and CI review

7. Dependency vulnerabilities

npm audit found 0 known vulnerabilities in 933 installed packages. The CI pipeline repeats the audit on every change and fails on any moderate or higher finding.

Critical	High	Moderate	Low	Info	Total
0	0	0	0	0	0

8. Residual risks and recommendations

None of these items is an exploitable weakness found in the build. They are controls that depend on the target environment or that we plan to add during implementation.

Area	Rating	Current position	Recommendation	When
Back-office MFA	Medium	Passwords alone protect back-office accounts today.	Add e-mail OTP or TOTP MFA for back-office users; Active Directory sign-on where available	Implementation, sprint 1
Web application firewall	Medium	No WAF in front of the portal in the test environment.	Place the portal behind IITH's WAF or a managed WAF with OWASP rules	Before SIT
Key management	Medium	Encryption keys are supplied as environment variables.	Hold keys in an HSM, cloud KMS or vault; rotate yearly using the key-version prefix	Before go-live
Malware scanning	Medium	Uploads are scanned only when CLAMAV_HOST is set.	Deploy ClamAV in every environment and make the setting mandatory in production	Before SIT
Database connections	Low	Database traffic is not encrypted inside the compose network.	Enable TLS to PostgreSQL and restrict the application role to the privileges it needs	Before go-live
Backup encryption	Low	Backup encryption depends on IITH's backup service.	Encrypt backups and test restores quarterly	Before go-live
SIEM integration	Low	Logs and audit records are not yet forwarded centrally.	Forward logs and audit events to IITH's SIEM; add alert rules	Implementation
Rate limiting behind proxies	Low	Per-client limits depend on the forwarded client address.	Set TRUST_PROXY_HOPS to the real proxy chain and tune limits after performance testing	SIT
Inbound API key path	Low	In the test run no key was configured, so the interface refused all calls (503).	Repeat SEC-30 with a configured key and confirm 401 for a wrong key	SIT
Independent assurance	High until done	No independent test has yet been performed.	Independent VAPT on IIFT's UAT or production-like environment with re-test (DEL-17)	Weeks 17–19

Table 8: Residual risks

9. Vulnerability severity and remediation timelines

Severity	Description	Timeline
Critical	Remotely exploitable; data exposure or system compromise	Contained within 24 hours; fixed within 7 days
High	Significant impact; exploitation likely	Within 14 days
Medium	Limited impact or hard to exploit	Within 30 days
Low	Minimal impact; hardening advice	Within 90 days or the next release

Table 9: Remediation timelines (NFR-12, MNT-12)

10. Independent VAPT plan

Item	Plan
Tester	Independent third party approved by IIFT; no involvement in building the solution
Environment	IIFT UAT or a production-like environment with production configuration and test data
Timing	Weeks 17 to 19 of the plan, after SIT functional exit
Scope	Portal, back-office, public e-signature page, APIs including system-to-system endpoints, web tier and hosting configuration
Approach	Authenticated (grey-box) testing per role plus unauthenticated external testing, against OWASP ASVS Level 2 and the OWASP Top 10
Rules of engagement	Agreed with IIFT IT security: test windows, contacts, data handling, no denial-of-service
Deliverables	Report with findings, severity and evidence; remediation by iorta; re-test report (DEL-17)
Exit criterion	No open Critical or High findings at go-live; Medium and Low tracked to the timelines in section 9

Table 10: Independent vulnerability assessment and penetration test (DEL-17)

Annex – Evidence files

Results in this report are read from the evidence files below when the report is built. The fingerprint is the start of each file's SHA-256 hash, so a reader can confirm which evidence a given version of the report was built from.

Evidence file	Size	SHA-256 (first 16 characters)
api-e2e-coverage-summary.json	46,528 bytes	6c079f523f5bfac0...
api-e2e-tests.json	933,978 bytes	42706cfb62722b95...
api-static-analysis.json	796 bytes	c089c515ae4ee33b...
api-unit-coverage-summary.json	42,137 bytes	be2af8466b49500f...
api-unit-tests.json	887,671 bytes	fa135bc56e5fab94...
code-metrics-api.json	759 bytes	2ca7d0802f7f1c9d...
npm-audit.json	366 bytes	1cf279e9ef691d09...
runtime-dependency-licences.json	40,391 bytes	b003a0dc1a75e06f...
security-checks.json	9,632 bytes	a1ce57e45ec687c6...

Table 11: Evidence files